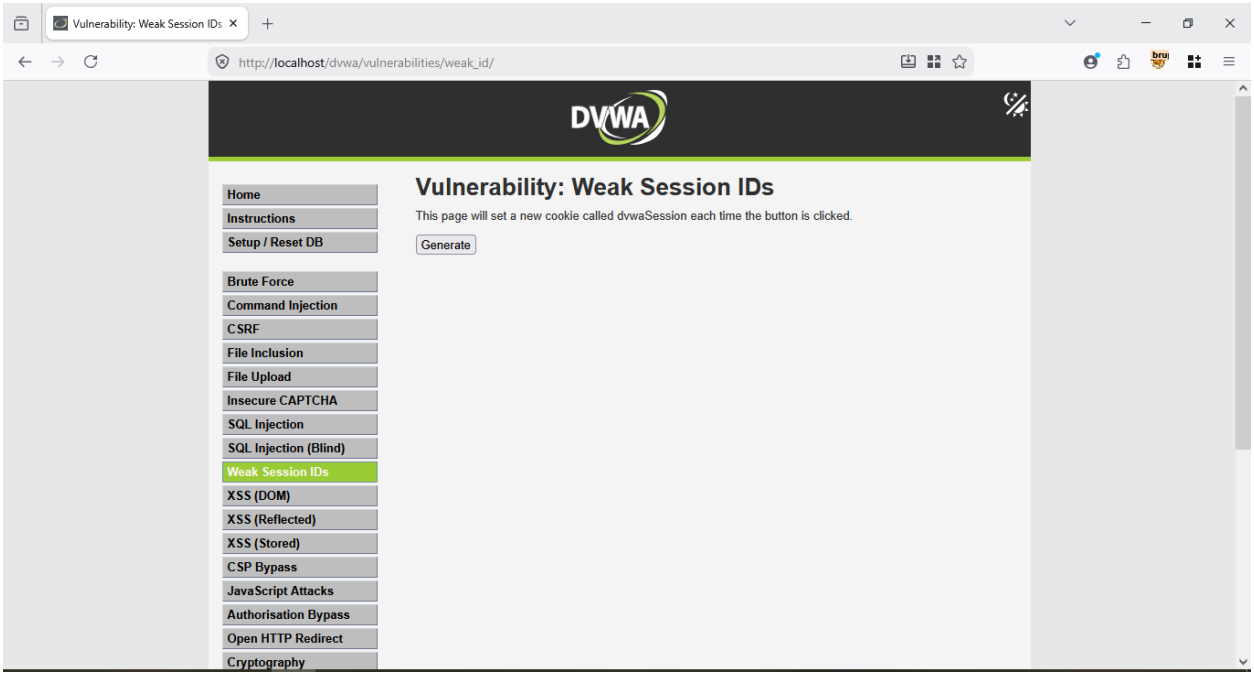
Weak Session IDs

Weak Session IDs pada DVWA (Damn Vulnerable Web Application) adalah kerentanan di mana token pengenal sesi (session ID) yang diberikan oleh server web kepada pengguna dapat diprediksi, ditebak, atau dimanipulasi dengan mudah. Hal ini membuka celah untuk serangan session hijacking.

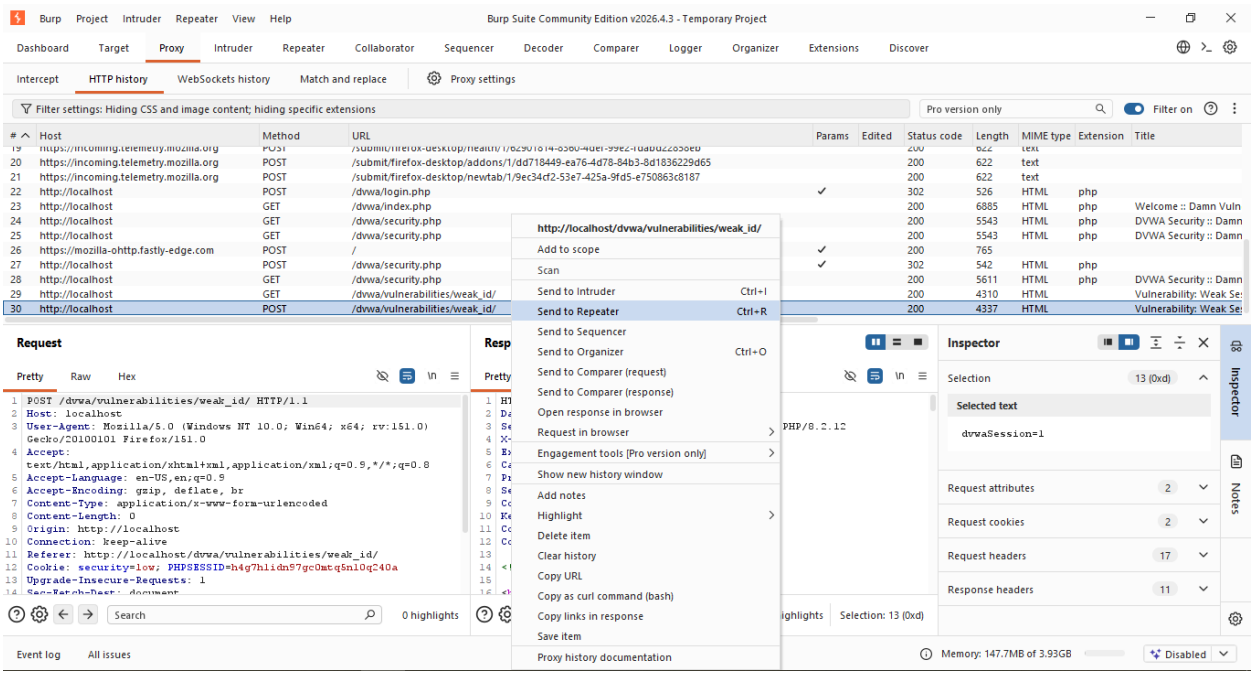
Mengetahui atau mencuri session ID (ID sesi) adalah salah satu pencapaian terbesar bagi seorang peretas karena memberikan akses langsung ke akun korban tanpa perlu mengetahui kata sandi.

Level Low : Session ID dibuat dengan pola yang sangat mudah ditebak, biasanya hanya berupa angka yang berurutan (misalnya 1, 2, 3, dan seterusnya) setiap kali sesi baru dibuat.

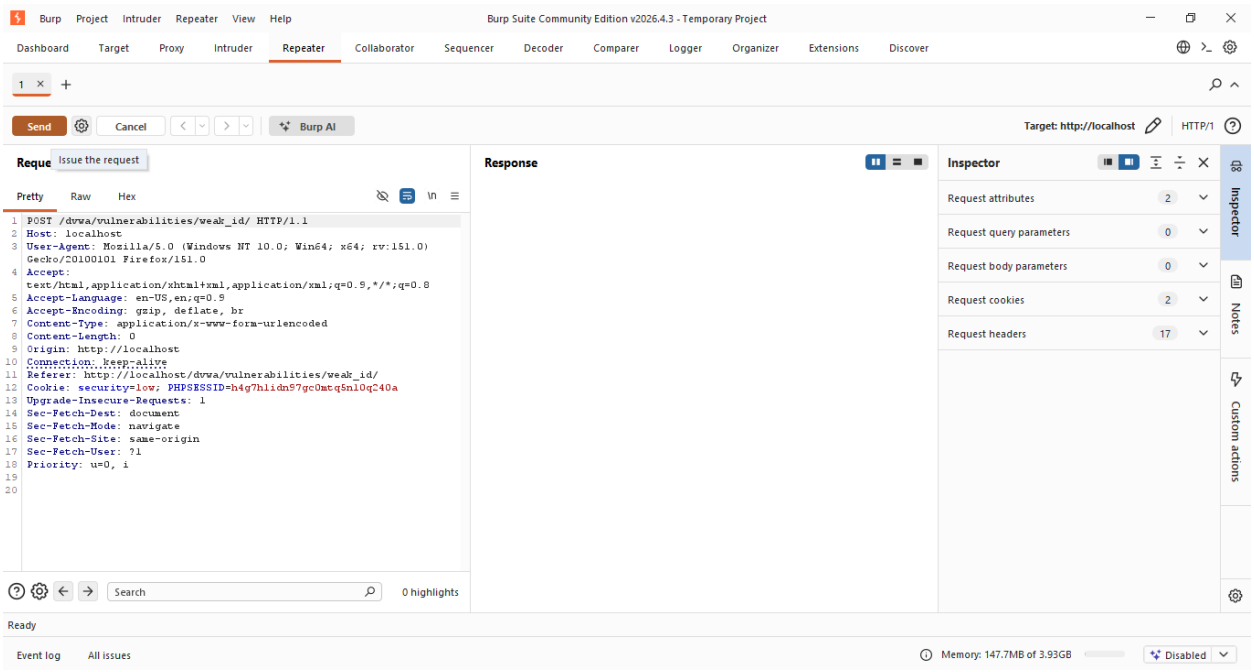
Aktifkan burpsuite kemudian buka dvwa Weak Session IDs kemudian klik generate

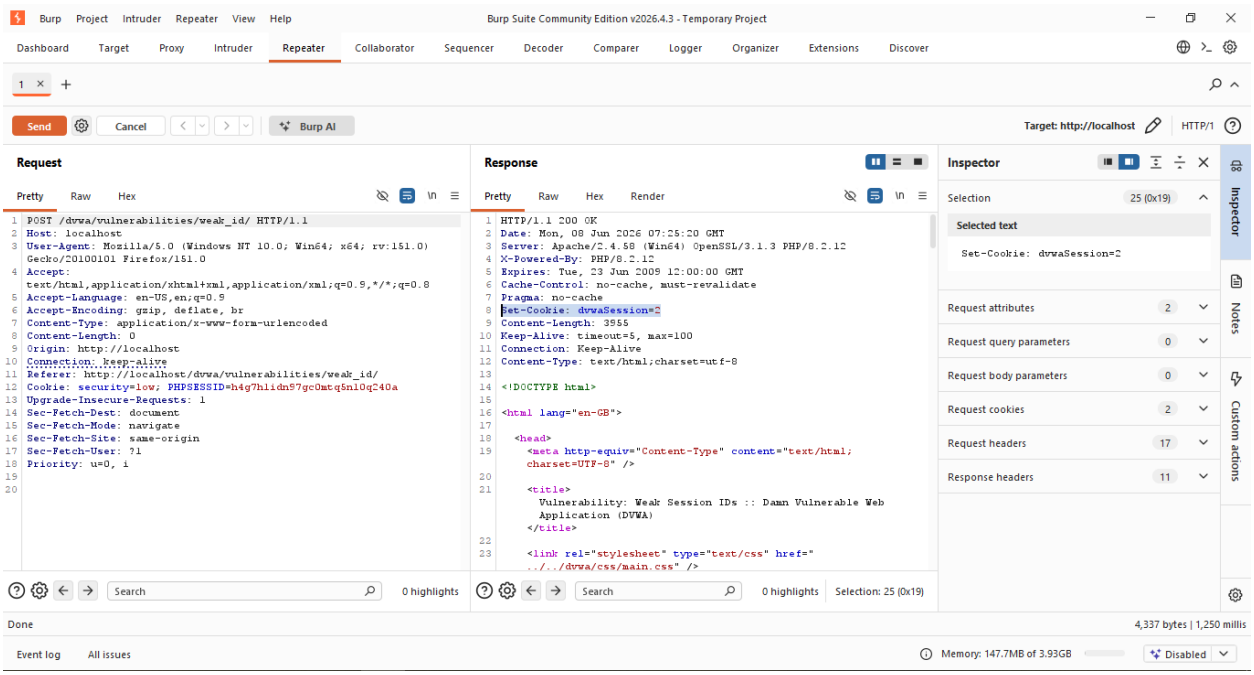


Disni merupakan cookie dvwa season kemudian kita kirim requestnya ke repeater



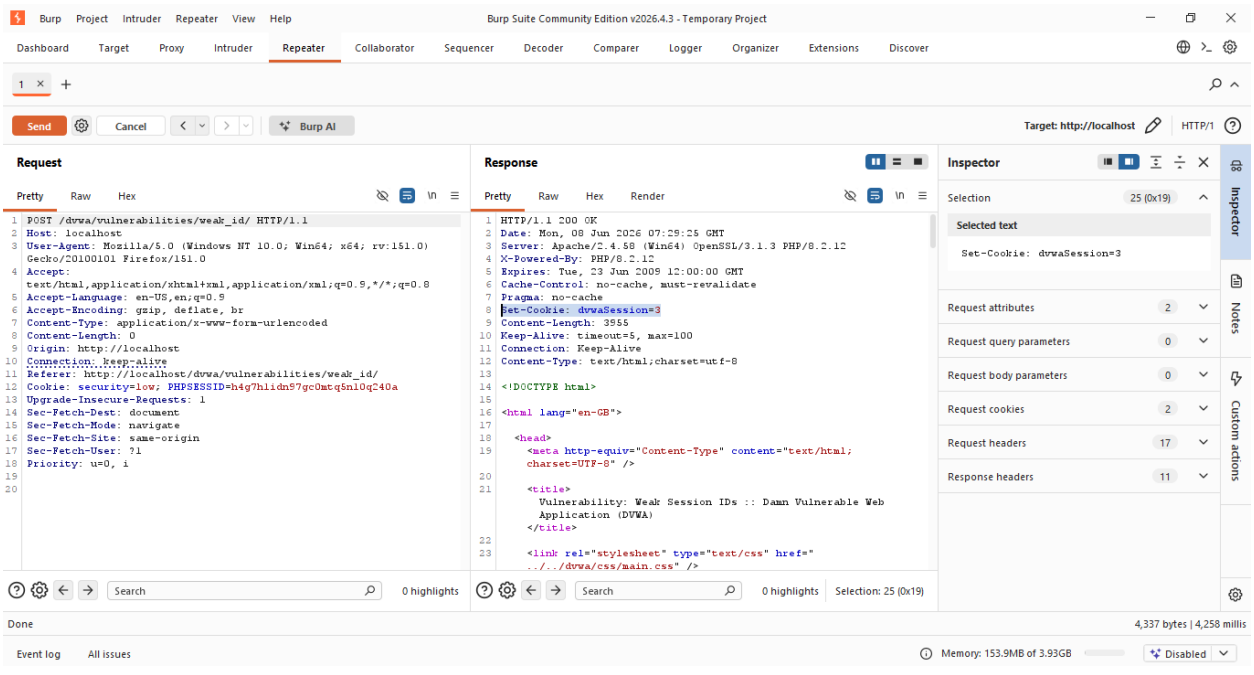
Kemudian pada repeater kita klik send





kita send kembali maka menjadi Set-Cookie: dvwaSession=3

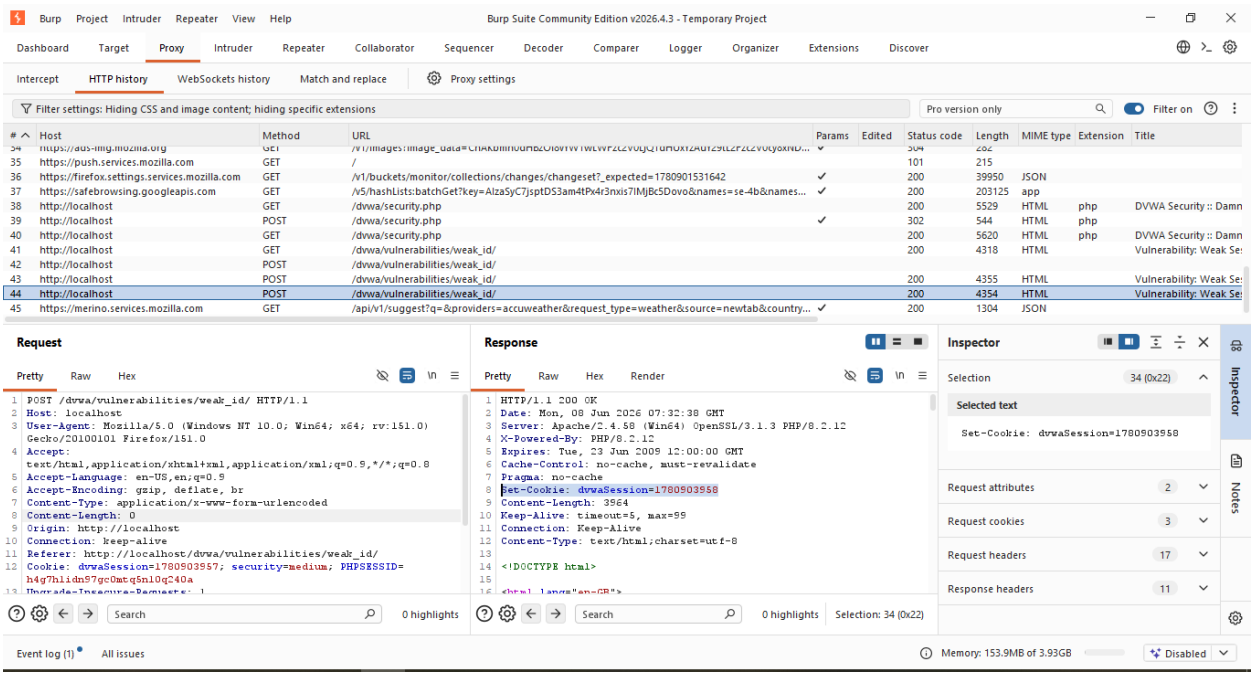
artinya bahwa nilai dvwa season di level low hanya menggunakan angka bilangan bulat (menggunakan tipe data integer) sehingga mudah sekali untuk di susupi.

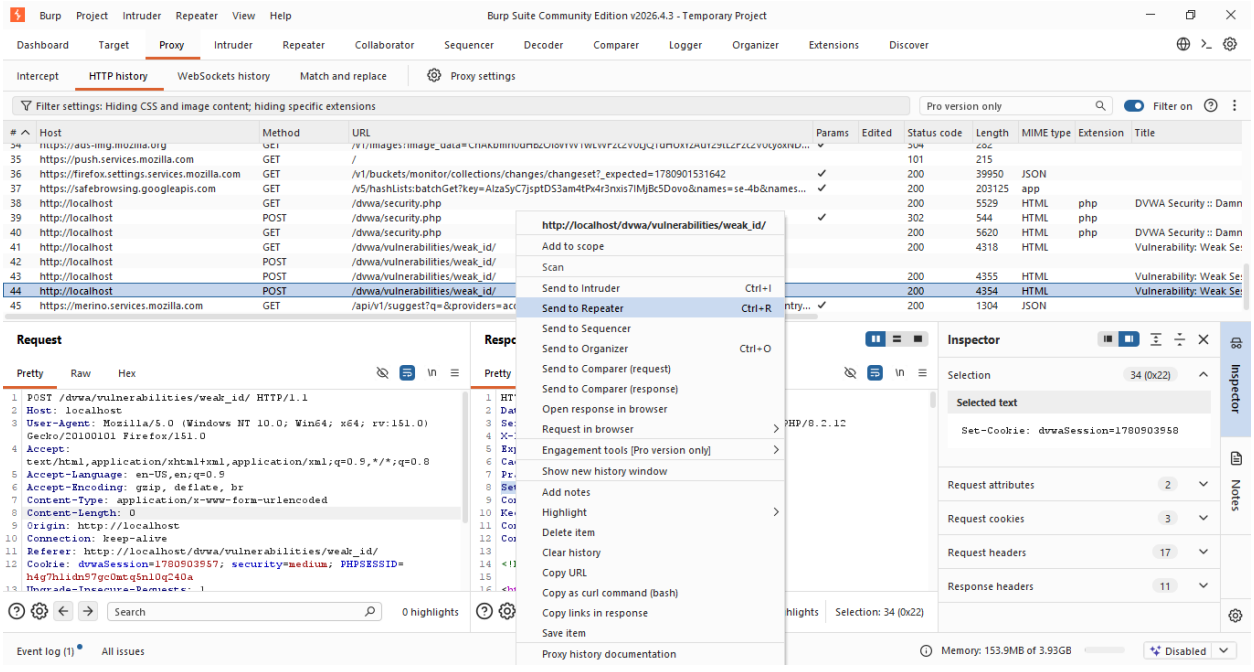


Level Medium : Session ID terlihat lebih acak dan panjang, namun sebenarnya menggunakan pola berbasis waktu (timestamp/waktu Unix saat ini). Penyerang dapat memperkirakan nilai token berikutnya jika mereka mengetahui waktu saat permintaan dibuat.

Level security medium

Aktifkan burpsuite kemudian buka kembali dvwa Weak Session IDs kemudian klik generate





Kemudian kita klik send maka kit abs lihat perbedaan nilai dvwa session

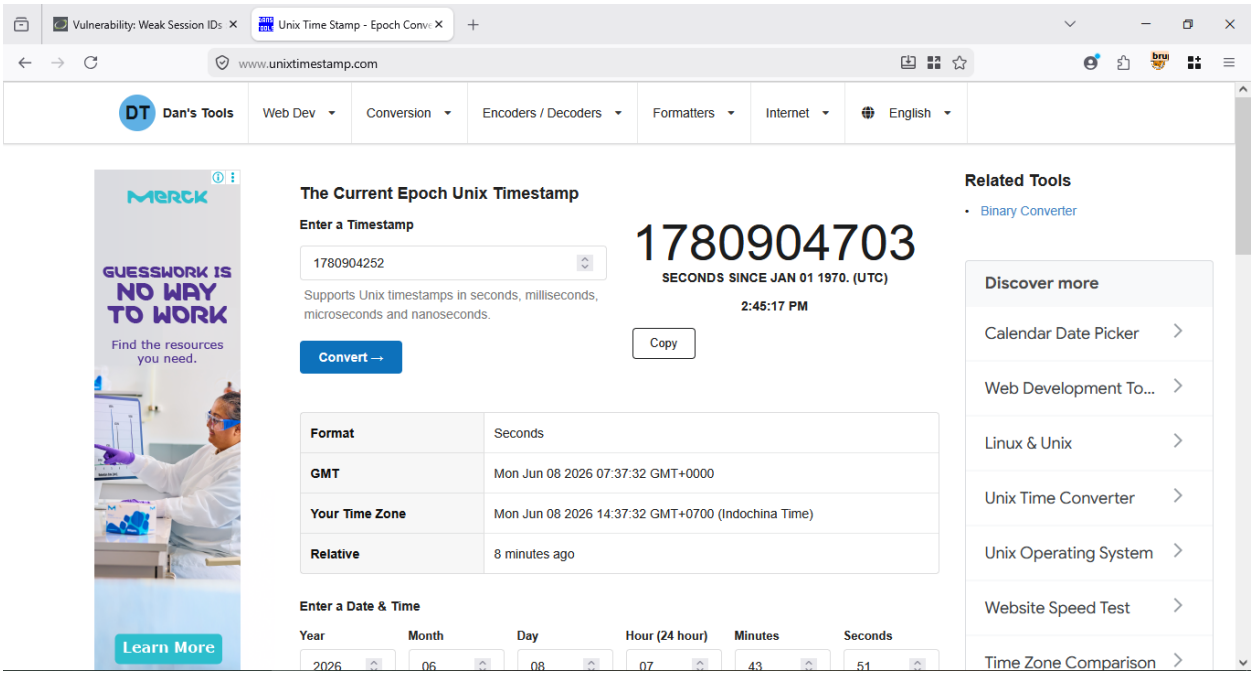
1 Set-Cookie: dvwaSession=1780903958

2 Set-Cookie: dvwaSession=1780904095

3 Set-Cookie: dvwaSession=1780904252

Berdasarkan nilai session tersebut kita bisa lihat format bilangan ini adalah unique timestamp adalah …

Kita aka coba cek dengan melalui situs https://www.unixtimestamp.com/



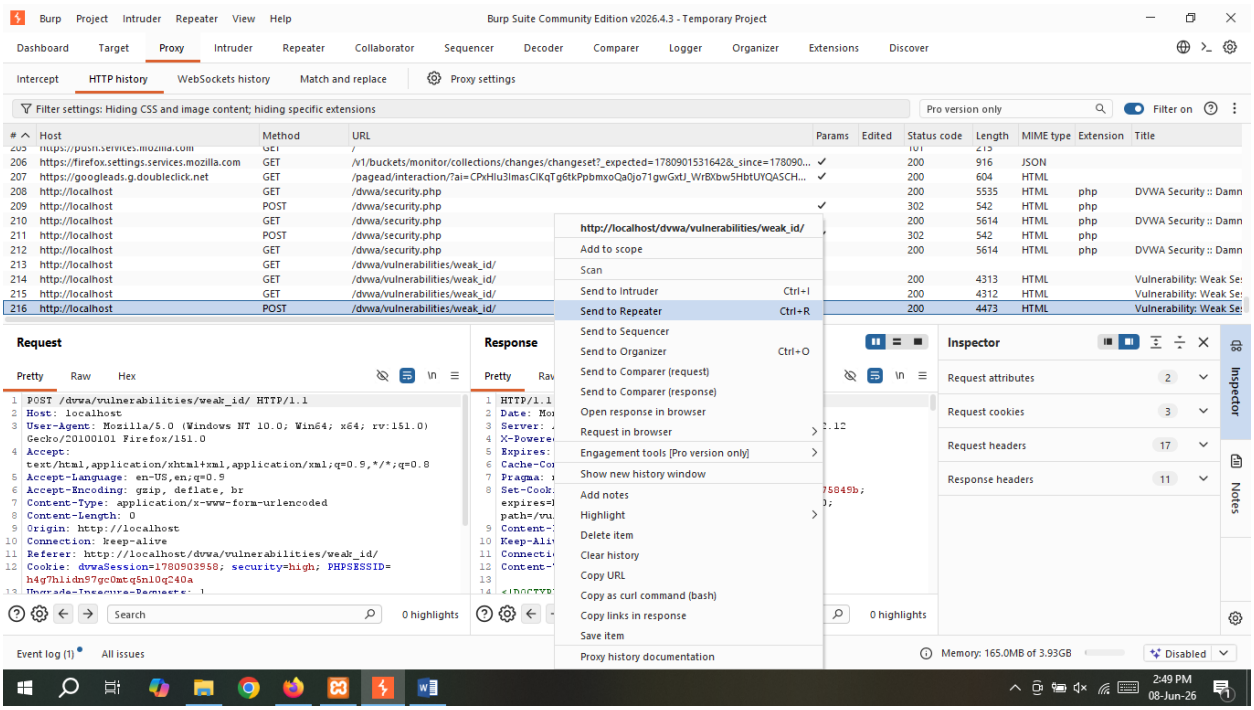
dvwaSession=1780904252 = Mon Jun 08 2026 14:37:32 GMT+0700 (Indochina Time)

jadi nilai unik dari dvwa level medium adalah berdasarkan dari unique timestamp

Level High : Menggunakan fungsi matematika enkripsi dasar (seperti MD5 dari gabungan timestamp dan angka acak) untuk menghasilkan token yang lebih rumit, namun masih bisa dianalisis dan direkayasa polanya.

Level security high

Aktifkan burpsuite kemudian buka kembali dvwa Weak Session IDs kemudian klik generate

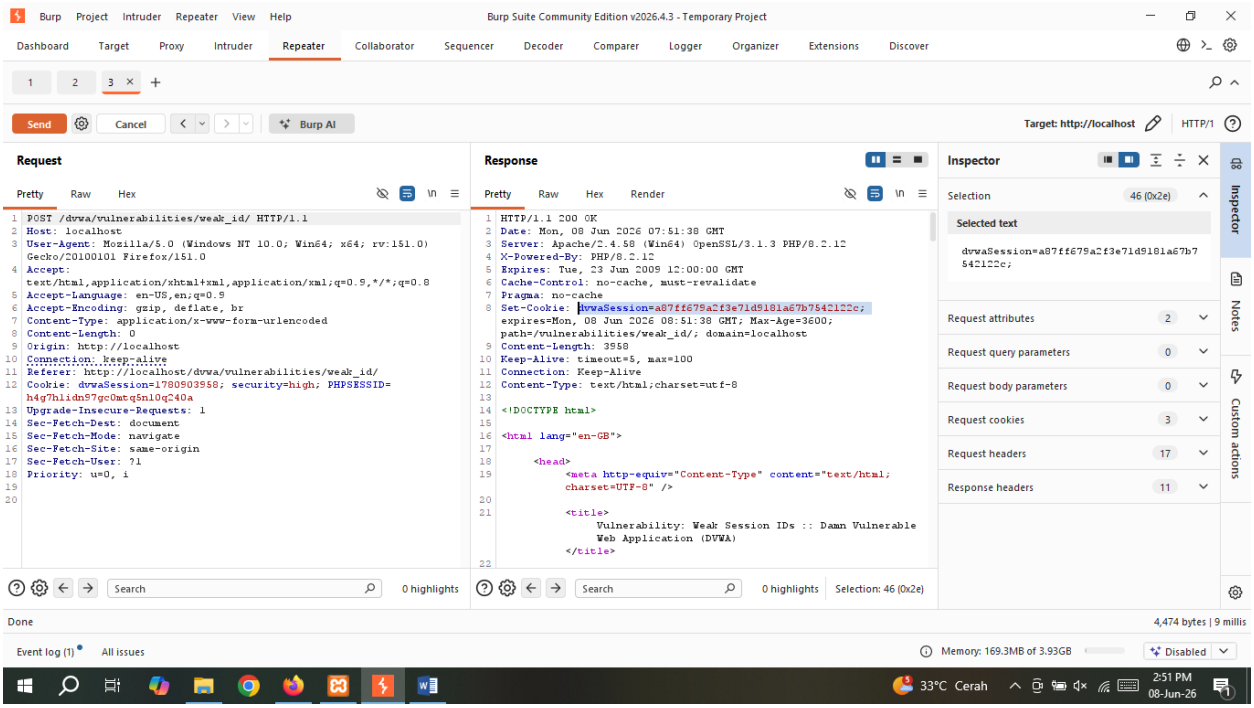


Kemudian kita catat dvwa session untuk mengamati kemudian kita send kembali

1 dvwaSession=c4ca4238a0b923820dcc509a6f75849b

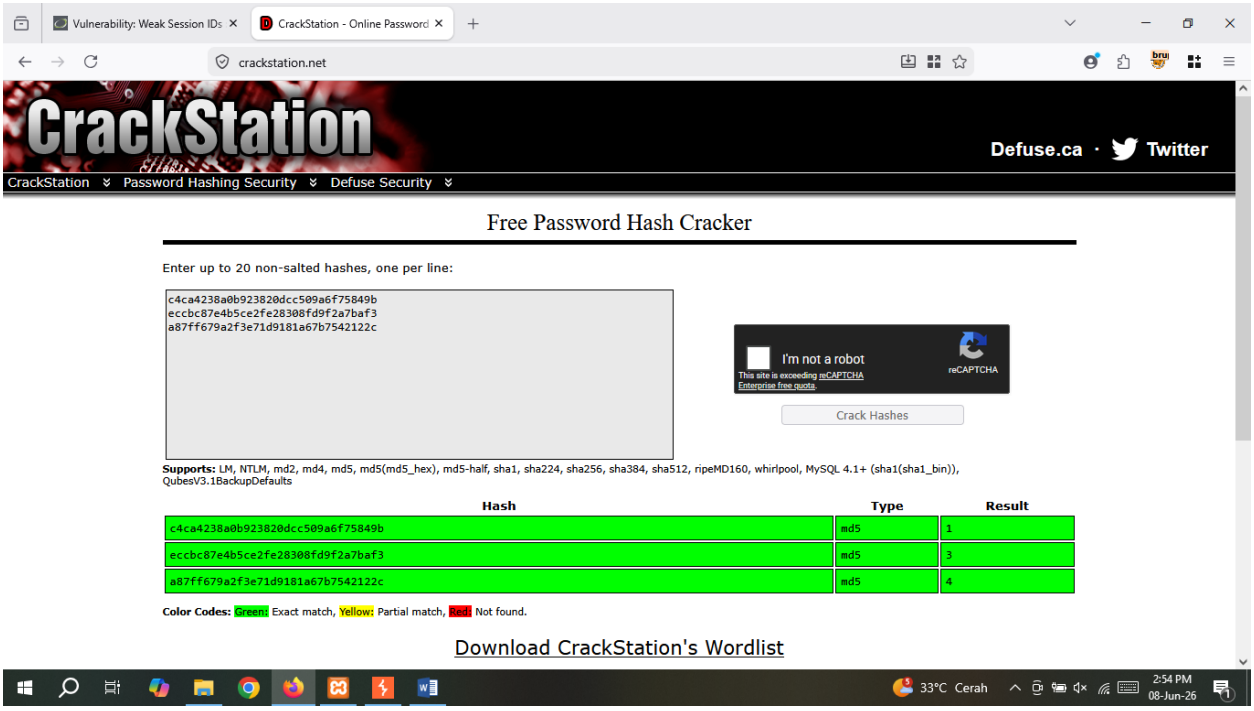
2 dvwaSession=eccbc87e4b5ce2fe28308fd9f2a7baf3

3 dvwaSession=a87ff679a2f3e71d9181a67b7542122c



Kemudian kita buka website https://crackstation.net/

Kemudian kita paste dvwa session tersebut



Jika kita amati pada level High dia menggunakan tipe data integer seperti level low hanya disini dia dirubah menjadi Hash type md5